

Assignment 2 – Final: Zero Trust Solution Design Document

GaruDyne Aeronautics case study

Younus Syed Jalal, Mahesh Nutheti | Zero Trust | 12/03/2025

Table of contents

- I. Executive Summary**
- II. Requirements and Foundations**
 - 1. Refined Scenario Summary**
 - 2. Critical Assets & User Classes**
 - 3. Zero Trust Maturity Assessment**
 - 4. Technology Landscape Summary**
 - 5. Preliminary Scope Diagram**
- III. Policy & Architecture Design**
 - 1. Technologies and components table**
 - 2. Build Architecture and Design Narrative**
 - 3. Threat And Resilience Considerations**
- IV. Implementation Strategy & Operations**
 - 1. Implementation Roadmap and Phasing Plan**
 - 2. Operational Processes and Governance Model**
 - 3. Metrics and Measure of Success**
 - 4. Operational Example Scenario**
 - 5. Sustainability and Continuous Improvement**
 - 6. Threat and Risk Context**
- V. Conclusion**

I. Executive Summary

GaruDyne Aeronautics is a global aerospace and defense manufacturer active across the United States, Europe, and Asia, with more than 60,000 employees and 10,000 contractors. Its operations rely on a hybrid technology environment that consists of on-premises CAD design systems, manufacturing OT networks, cloud-based HR and supplier platforms, and high-performance R&D environments. As a defense contractor, GaruDyne is up against nation-state adversaries, supply-chain intrusions, insider threats, and strict regulatory obligations including ITAR, CMMC, GDPR, and FAA Production Certificate requirements.

Today, GaruDyne's environment depends almost entirely on perimeter-based VPN access, decentralized identity systems, non-uniform device compliance, limited supplier oversight, and inconsistent data classification. These vulnerabilities create opportunities for credential misuse, lateral movement, data exfiltration/loss, and operational disruption. Global industry events attached to aerospace and defense organizations imply that traditional perimeter security is no longer sufficient to secure GaruDyne's global collaboration needs or protect its IP. To confront these obstacles, this Solution Design Document offers an extensive Zero Trust Architecture aligned with **NIST SP 800-207**, **NIST SP 1800-35**, and the **CISA Zero Trust Maturity Model v2.0**. The architecture highlights identity-centric authentication, device posture incorporation, micro segmentation, dynamic access policies, and continuous validation based on telemetry and behavioral analytics. The recommended technology stack—Microsoft Entra ID, Okta, Cisco ISE, Zscaler ZPA, Intune, CrowdStrike Fusion, Microsoft Purview, and Splunk SIEM + UEBA—provides a centralized platform for implementing least-privilege access across users, devices, networks, applications, and data. The implementation of roadmap propels GaruDyne from foundational controls to an upgraded, automated Zero Trust operating model over multiple stages. This transformation solidifies supply-chain security, improves transparency across IT and OT environments, reduces incident response time, and guarantees sustained compliance with defense and privacy regulations.

Expected Consequences include:

- **80–90% decrease in credential-based attack surface** through widespread MFA, SSO, and risk-based access.
- **Eradication of broad VPN exposure** via ZTNA and identity-aware segmentation.
- **Enhanced protection of CAD and R&D data** through classification, encryption, and DLP policies.
- **Strengthened vendor governance** with centralized identities and monitored access.

This Solution Design Document integrates the scoping, architecture, and implementation phases into a coherent strategy that GaruDyne can execute immediately.

II. Requirements & Foundation

1. Refined Scenario Summary

Organization profile:

Garudyne Aeronautics is a multinational aerospace and defense manufacturer which designs and makes commercial aircraft, drones, and military systems.

- With over 60,000 employees and 10,000 contractors, Garudyne operates across North America, Europe, and Asia.
- The IT environment at Garudyne is of a hybrid nature consisting of both on-premises and cloud systems, applications etc. It Includes on premise CAD and manufacturing execution systems (MES), cloud-based SaaS applications for collaboration and HR management and manufacturing Operational Technology (OT) Devices.

Core Business Problem:

Garudyne presently functions under a conventional Perimeter security model but deals with but deals with rising targeted cyber-attacks from nation states and supply chain risks. Its wide VPN access, restricted transparency into vendor activity, and irregular device management can disclose intellectual property and sensitive data. The company has decided to adopt zero trust architecture to update access controls, reinforce data security, and upgrade compliance globally.

Business objectives:

Zero trust adoption can be accomplished by:

- Safeguarding intellectual property and design data from espionage and insider threats
- Provisioning secure remote engineering and hybrid collaboration.
- Guaranteeing supply chain integrity and 3rd party accountability.
- Making sure the organization is in compliance with ITAR, CMMC, GDPR, and FAA production requirements.
- Increasing resilience and reducing downtime in the wake of cyber security incidents.

– **Critical Assets & User Classes**

To depict the Zero Trust scope, the following assets and user categories have been obtained as the most crucial to the business based on GaruDyne’s operations, regulatory exposure, and risk profile.

Asset	User Classes	Data Sensitivity	Rationale
CAD Design Servers	Senior engineers [remote and on site]	Confidential	These servers are used to create and store proprietary aircraft and drone design files protected under ITAR crucial to IP protection.
Supplier portal	External vendors/Manufacturers	Internal /Confidential	Manufacturers upload specifications and data onto the portal with unmanaged devices.
MES Dashboards & Sensors	Production Supervisors/engineers	Internal Use	Crucial for managing production environment and FAA Production Compliance.
HR Databases and Employee Records	HR staff/Managers	Confidential (PII)	Contains Sensitive Personnel Data and has to be compliant with GDPR.
R&D Cloud HPC Environment	Research Teams	Confidential	Holds Simulation Models and AI datasets,

2. Zero Trust Maturity Assessment

Overall, GaruDyne's Zero Trust maturity places itself between Traditional and Initial, with some environmental aspects showing movement toward Advanced (network segmentation). The organization has initiated the enabling of MFA and SSO but lacks federated identity governance, device posture incorporation, micro segmented network paths, and coherent data protection. The CISA v2.0 model clearly references that advancement requires enterprise-wide identity federation, centralized device trust signals, workload-level authentication, and a robust data governance project. These needs directly push the priorities selected in the subsequent parts of this engagement.

Zero Trust pillar	Current level	Notes
Identity	Initial	GaruDyne has an MFA implemented exclusively for VPN access and a small set of internal systems. SSO scope is inconsistent across SaaS applications, and supplier identities depend heavily on password-based authentication. The case study emphasizes a lack of identity governance for third-party vendors and risk-based access decisions, mapping CISA's Original characteristics (limited federation, minimal MFA, fragmented identity stores).
Devices	Traditional	A large part of the infrastructure, including OT devices, IoT sensors, and BYOD endpoints, continue to be unmanaged, with patchwork and minimum posture validation. This portrays CISA's Traditional maturity where organizations do not have centralized asset inventories and device trust signals. There is a lack of influence on device posture on access decisions, matching the scenario aspects.
Networks	Initial - Mid-Initial	The case study indicates large VPN access for remote engineers, suppliers, and internal staff which clearly points to a flat network access pattern, characteristic of the Traditional/Initial level. It also mentions that security concerns exist regarding attackers jumping between systems once inside, displaying a lack of micro segmentation. While GaruDyne most probably upholds

		baseline OT/IT segmentation (separate MES and manufacturing networks), this is a standard operational procedure and does not provide evidence of Advanced Zero Trust segmentation. Hence, the case evidence points to a rating between Traditional and Initial, but not Advanced.
Applications	Initial	The case study reflects many legacy applications such as CAD servers, ERP, MES, and HR systems. Most of which rely on conventional authentication and provide broad access post-logging in. An obvious lack of API-level authorization, workload identity, or modern service mesh patterns. Supplier portals allow uploads without context-based access and lack granular access control. These gaps align to CISA’s Initial maturity definition, to how application access lacks granular access controls, and workload identities do not influence policy decisions. .
Data	Traditional	The case study rigorously emphasized risk to CAD files, proprietary R&D models, supplier documentation, and HR records. Although, there is no mention of standardized data classification, DLP policies, Uniform encryption, or labelling of sensitive content. Non-existent centralized data governance positions GaruDyne in the Traditional maturity stage. As per CISA ZTMM, environments in this phase have “ad hoc or inconsistent data protections” and lack transparency into sensitive data flows—both true for GaruDyne today.

4. Technology Landscape Summary

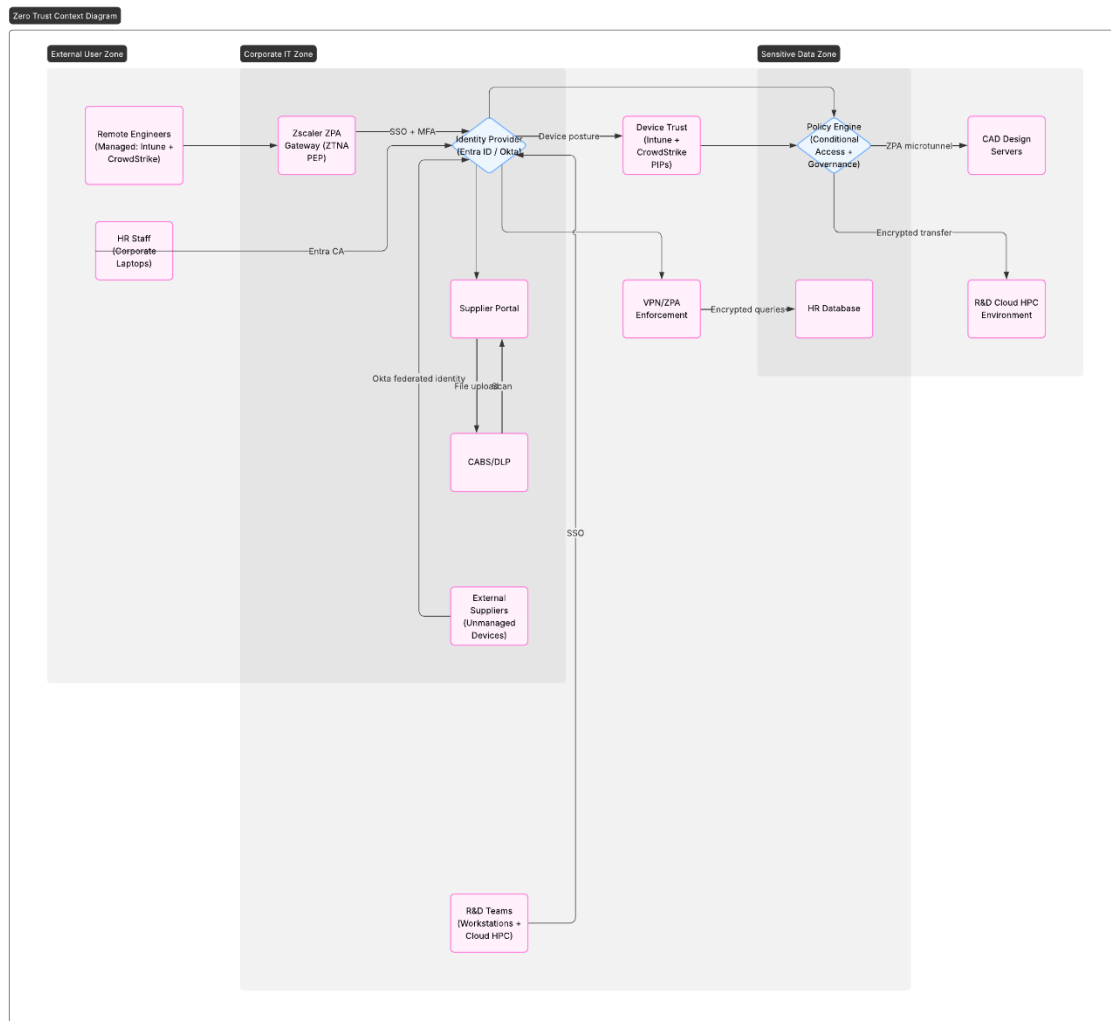
Category	Current Technologies	Future Phases
Identity and Access Management (IAM/SSO)	Assure AD for employees and few older applications still rely on local LADP. Limited MFA through VPN for limited users.	Expand Assure AD with conditional access and SSO for SaaS applications, Integration of OKTA to manage the third-party vendor accounts.
Network Access Control (NAC/AAA)	Network security is completely dependent on traditional VPN and basic firewall segmentation.	Implement Aruba ClearPass or Cisco ISE to verify device identity and to automate the security posture assessment.
Endpoint Encryption / MDM	Manual patch cycles, devices use standard antivirus, and there is no centralized mobile or OT device management.	Deploy EDR/XDR solutions and MDM tools such as CrowdStrike Fusion or Microsoft Intune to enforce device trust.
Visibility and Analytics / SIEM	Central SIEM collects limited logs from OT and cloud environments, which offers limited real time alert monitoring.	Extend SIEM coverage to OT networks and cloud systems, integrating UEBA for continuous behavior-based monitoring.
Cloud Security / ZTNA	Azure and AWS SaaS environments have native controls, but there is no ZTNA layer in place.	Introduce CASB for data governance by deploying Zscaler ZPA or Prisma Access for secure Zero Trust Network Access.

5. Preliminary Scope Diagram

Diagram Elements:

- **User Groups:** Remote engineers, Suppliers, Factory Supervisors, HR Staff, R&D Teams.

- **Assets:** CAD servers, Supplier Portal, MES Dashboards, HR Database, R&D Cloud HPC.
- **Trust Boundaries:**
 - External Users (Internet -> ZTNA Gateway -> Corporate Network).
 - Internal Users (VPN / LAN -> Applications -> Data Stores).
- **Data Flows:**
 - Remote Engineers access CAD via SSO + MFA.
 - Suppliers upload specifications to portal under conditional access.
 - IoT sensors feed MES dashboards for segmented corporate networks.
 - HR and R&D users access confidential data through Azure AD conditional policies.



III. Policy & Architecture Design

1. Technologies and components table

To execute Garudyne's Zero Trust framework, these technologies were chosen and translated to their key roles (PE, PA, PEP, PIP) access based on context, continuous validation, and automation.

ZTA Component	Production/Implementation	Functions with ZTA build
Policy Engine	Microsoft Entra ID Conditional Access + Okta Identity Governance	Analyses context of access rules) user role, MFA Device Posture, Geolocation) And relays authorization decisions.
Policy Administrator	CISCO ISE + Azure Conditional access policies	Executes the PE's Decision through Enforcement commands to network and application gateways.
Policy Enforcement Point	Zscaler ZPA Gateways + palo alto firewall rules + aruba switch ACLs	Implement access control, Micro segmentation, and session policies for user and device traffic.
Policy Information Points	Microsoft Intune, CrowdStrike Fusion, Splunk Siem, Ueba Module	Provides data regarding dynamic context to PE and PA.
Identity Provider (IdP)	Entra ID is federated with OKTA for 3 rd party vendors.	Authentication of users and suppliers THROUGH THE USE OF mfa,sso and conditional risk-based access.
Network Access Control	CISCO ISE + 802.1X integration	Verifies device posture and certificates using 802.1X, enforces segmentation by using dynamic VLAN

		assignments for OT/legacy systems or Scalable Group Tags (SGTs) for modern IT environments.
ZTNA Gateway/ SASE	Zscaler ZPA/ZIA Stack	Provides identity-centered secure remote access to CAD, HR, and R&D applications with hidden VPN.
Data Protection and DLP	Microsoft Purview = CASB Integration	Applies Data classification, encryption at rest and in transit, and policy- based data loss prevention.
Visibility and analytics	Splunk SIEM+UEBA +Azure Sentinel	Appends logs across OT/IT to detect anomalies and supply policy feedback to PE.
Governance/ Automation Layer	Python+ PowerShell Scripts + terraform modules	Automation of Identity onboarding, device registration, and micro segment rule deployment through CI/CD.

2.Build Architecture and Design Narrative

i. Logical Architecture

Garudyne's Zero Trust Architecture is structured in a way that surrounds the five CISA/NIST Pillars – Identity, Device, Network, Application/Workload, and Data – assisted by a central Policy Decision Framework.

- **Policy Engine:** Entra ID conditional access and okta Identity Governance provide the approval for access based on identity signals, device posture, risk score, and geolocation.
- **Policy Administrator:** Cisco ISE translates these decisions into network actions such as VLAN assignments for OT/legacy systems and Scalable Group Tags (SGTs) for modern IT environments.

- **Policy Enforcement Points (PEPs):** Zscaler ZPA Connectors and Palo Alto Firewalls behave as gateways to implement the PE's authorization decision.
- **Policy Information Points (PIPS):** CrowdStrike Fusion, Intune, and Splunk Provide real-time telemetry on users, device compliance and threat detection which helps make decisions using this data.

This architecture makes sure that trust decisions are dynamic. Every access attempt is evaluated using current identity and contextual data.

ii. Trust Flows

Trust flows generally are established, evaluated, and continuously re-verified via a series of coordinated processes that have scope over identity, device posture, policy decisioning, implementation, and telemetry.

- **Authentication:** User authentication via ENTRA ID with MFA and SSO. Okta manages external suppliers via federated trust.
- **Context Collection:** Intune and CrowdStrike maintain device posture data (e.g., encryption status, patch level, EDR, agent health)
- **Policy Evaluation:** The PE maps identity, device, location, and behavioral data to create a risk score. Access is provided based on the conditions met.
- **Enforcement:** Cisco ISE applies to VLANs or SGTs and forwards these tags to switches, firewalls, and ZPA enforcement. Zscaler ZPA verifies session tokens and allows application-specific access.
- **Monitoring & Feedback:** Splunk SIEM monitors session logs, detects anomalies through UEBA, and supplies results back to the PE for policy administration creating a validation loop.

iii. Integration Points

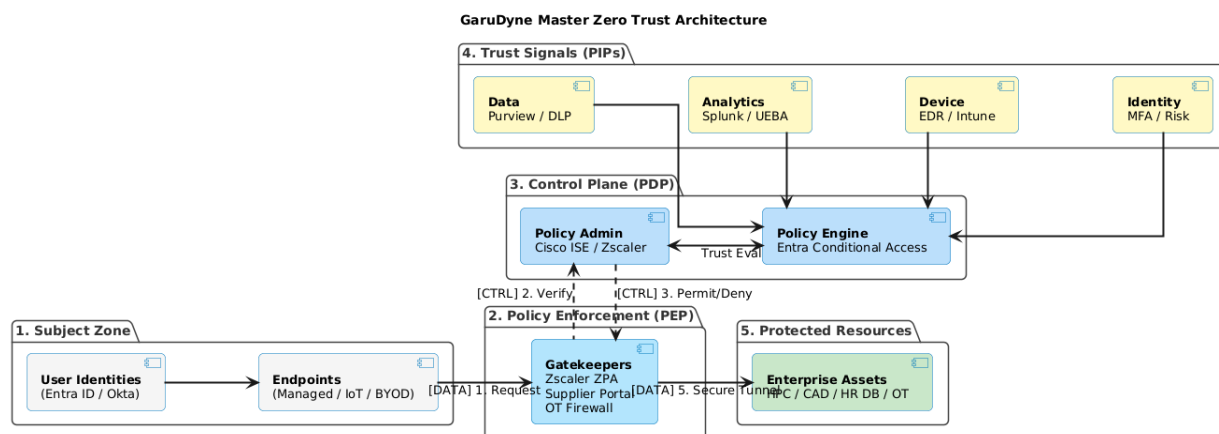
- **Identity to Network:** Entra ID conditional access provides verified identity and group attributes to Cisco ISE. Cisco ISE uses them to assign appropriate segmentation methods, using SGT or VLAN as needed.
- **Network to ZTNA:** ISE requests Zscaler ZPA to open application tunnels for authenticated sessions.
- **Device to Policy engine:** Intune and CrowdStrike transmit device data through API to EntraID.
- **Siem to PE:** Splunk alerts go directly into Azure Sentinel playbooks to initiate access revocation or conditional policy updates.

iv. Continuous Validation

Garudyne's design consists of continuous monitoring for both identity and device posture.

- **Telemetry flow:** Intune to CrowdStrike to Splunk to UEBA TO Azure Sentinel
- **Automated Actions:** Non-Compliant devices are isolated via ISE dynamic VLAN. Users exceeding risk threshold are forced to reauthenticate.
- **Zero Trust Loop:** Authenticate to authorize to validate to Reevaluate.

This makes sure that access is valid only as long as the context is trusted and verified.



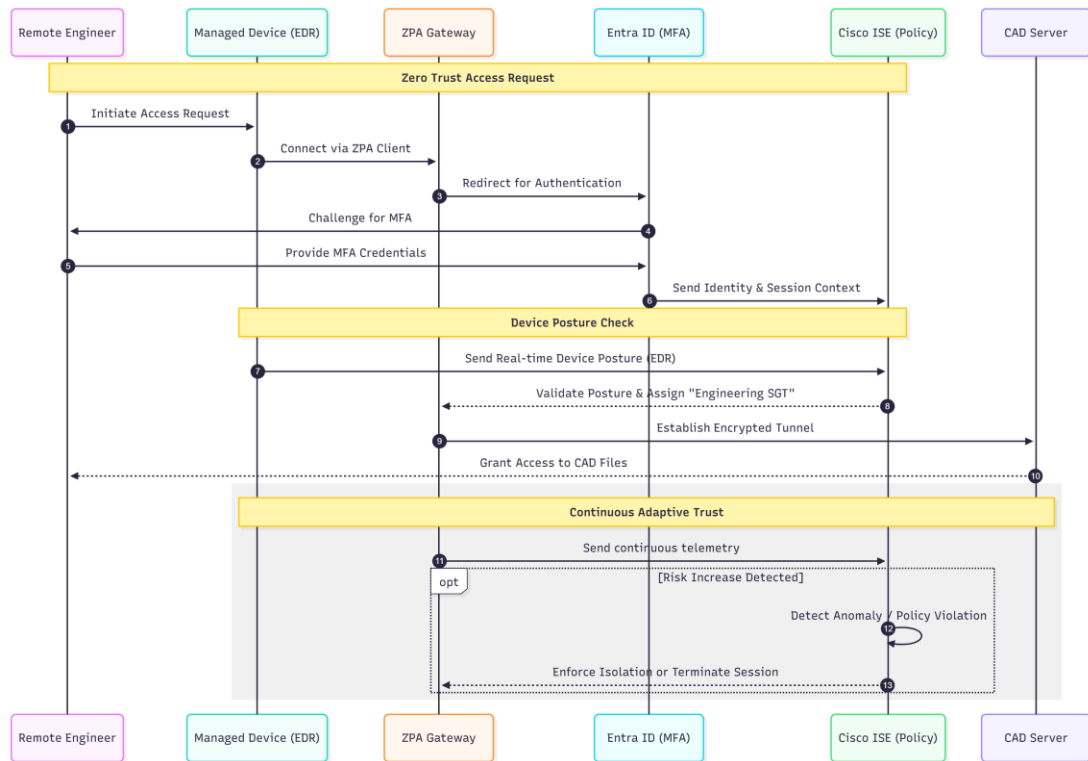
3. User / System Request Table

To mobilize GaruDyne's Zero Trust design, specific access policies were matched to the five core business scenarios provided in the case study. Each policy statement below portrays how the Policy Engine studies the trust signals from identity, device, network, and data sources to implement least-privilege, continuously validated access decisions.

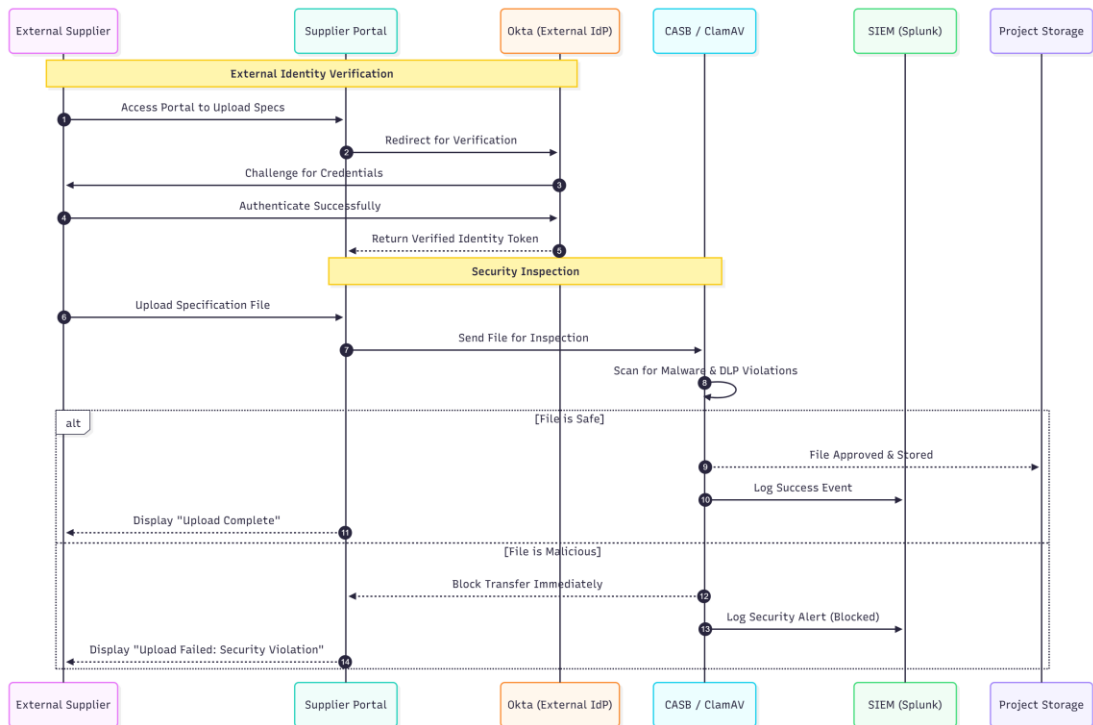
Access Request	Policy Statement	Trust Signals Used	Policy Type
Remote Employees Accessing CAD Files	Access is allowed only from compliant managed devices with MFA and an active EDR during approved hours. Cisco ISE assigns the appropriate VLAN/SGT. If the risk increases, read-only access, step-up MFA, or isolation is applied before termination.	User Role, Device Compliance, MFA, Time, Geo-Location.	ABAC

Suppliers Uploading Specifications Requests	Supplier access is permitted only through Okta-verified external identities. All uploaded files must pass CASB and ClamAV inspection, and every action is monitored through the SIEM for logging, anomaly detection, and compliance requirements.	Supplier identity, SSO Verification, CASB Scan Results, File integrity.	Contextual Policy
IoT Sensors on Factory	Unmanaged IoT devices will be segmented into OT-specific VLANs with strictly whitelisted, encrypted communication paths, and entire traffic will be continuously monitored for anomaly detection.	Device Certificate, Encryption / Protocol Status, Network Telemetry.	Risk-Based Policy
HR Employee Accessing Personnel Data	HR employees are only allowed to connect through the corporate network or an approved ZPA session, requires MFA, and device health compliance is required. All sensitive queries are monitored, logged, and automatically flagged for review.	Identity, Device Health, MFA, ZPA / Network Status.	RBAC + ABAC
Research Team Uploading Latest Models	R&D user's access HPC resources through SSO, and all uploaded data must be encrypted and properly classified, with large file transfers continuously monitored and logged by the SIEM.	User Role, Encryption Status, Data Classification, SIEM Alerts.	ABAC + Risk Adaptive

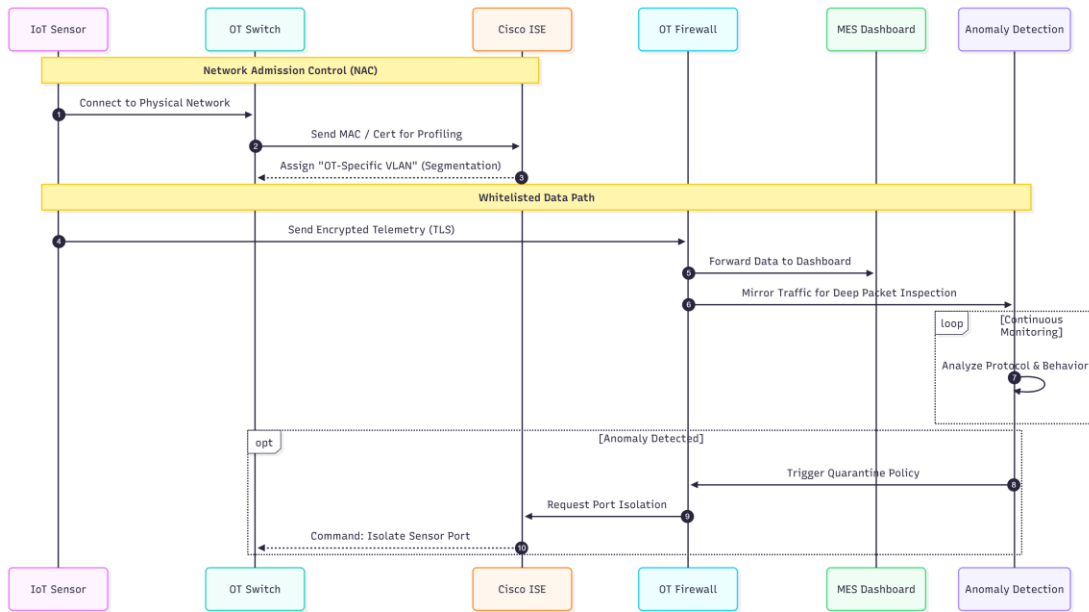
Remote Employees Accessing CAD Files



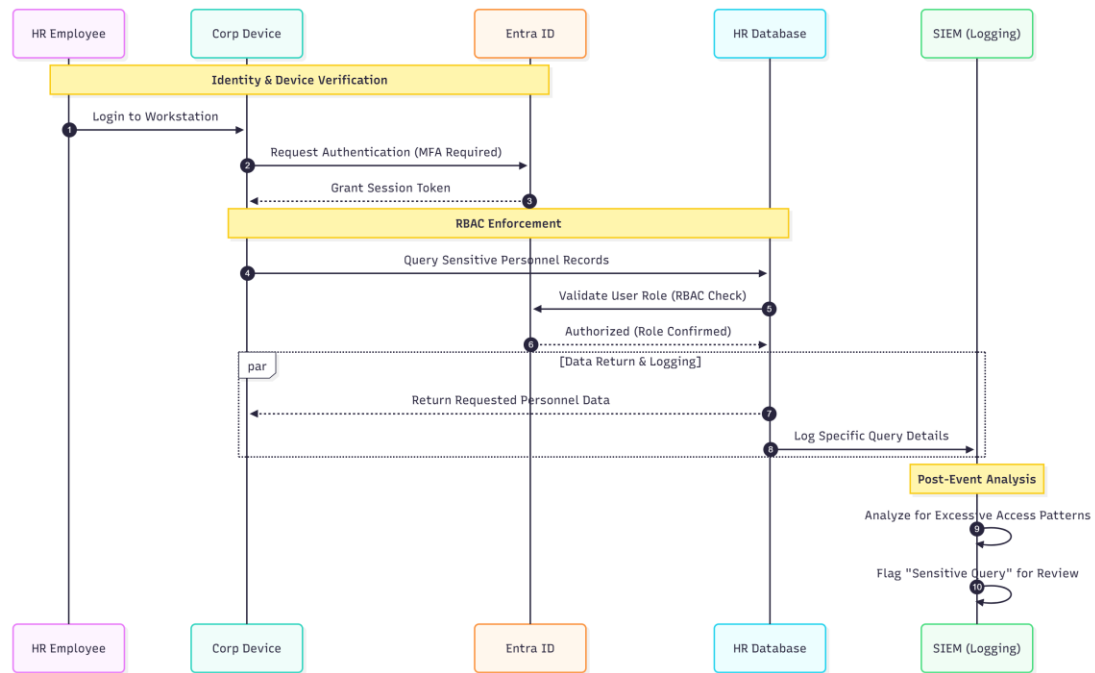
Suppliers Uploading Specifications Requests



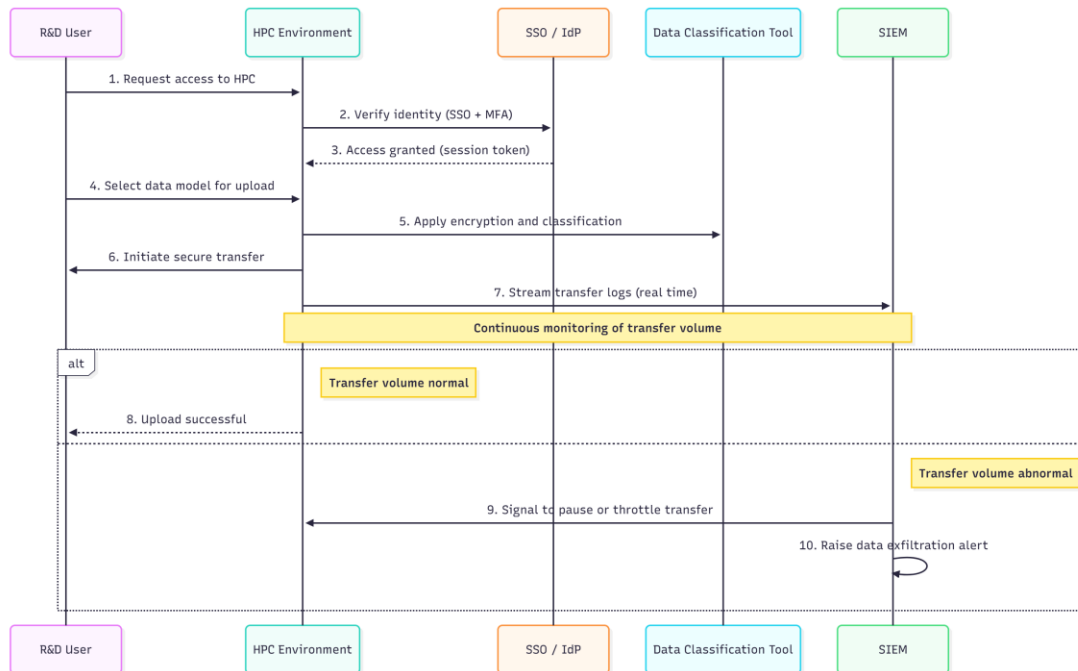
IoT Sensors on Factory



HR Employee Accessing Personnel Data



Research Team Uploading Latest Models



Policy Narrative:

These policies collectively establish complete control over all data movements across the GaruDyne's Zero Trust environment, ensuring that every request, access, and exchange is secured and logged. When HR staff or engineers request sensitive data, their identity, MFA, and device compliance are validated before encrypted data is securely transmitted to approved managed devices.

Supplier's uploads will first go through Okta federated identity validation, then pass through malware analysis tools and CASB inspection, ensuring only clean, verified, and secure files to flow into the organization. IoT devices data within the organization passes through segmented and isolated OT VLANs, where this data is monitored in real time for abnormalities before it enters into the organization's analytic environment. Research teams uploading large files to HPC environment must use SSO, classify the data into appropriate classifications, and encrypt the data. All the transfer and uploads will be continuously monitored by SIEM for abnormalities outside the current pattern. Across all of these scenarios, data cannot be transmitted, accessed, and stored until user identity, device posture, context, and risk signals are verified. Every activity from login using authentication to requested file transferred will be logged, analyzed, and continuously inspected to prevent lateral movement, detect anomalies, and ensure the safety and integrity of GaruDyne's Zero Trust environment.

4. Threat And Resilience Considerations

Adversarial Tactic	Mitigation Strategy
Credential Phishing	Multi Factor Authentication (MFA) will be enforced using Azure AD, Okta to verify user identity before granting access, and session tokens will be used for short lived devices on the network. User and Entity Behavior Analytics (UEBA) by Azure Sentinel will be deployed to continuously monitor and terminate the session if any device behavior is outside the established pattern.
Privilege Escalation	Attribute-based and Role-based access control policies will be implemented using Cisco ISE to implement micro segmentation and Zscaler Private Access (ZPA) tunnels to establish secure tunnels to restrict the movement between network and application segments. These following measures will minimize the risk of lateral movement across the network.
Data Exfiltration	Microsoft Purview Data Loss Prevention (DLP) and Cloud Access Security Broker (CASB) will continuously monitor the file transfer and data movement across the environment. SIEM will monitor, analyze, and generate alerts in case of unusual bulk downloads or upload patterns are found. Conditional policies will automatically quarantine or block the unidentified or non-compliant devices which reduce the risk of data exfiltration.

Resilience Mechanisms:

- **Redundant ZTNA Gateways:** Multiple ZTNA gateways will be deployed across the organization to ensure availability and operational continuity.
- **Auto Policy Rollback:** In case of policy failure or any issues with new policy implementation occurring, the systems will automatically roll back to previous versions.
- **Sentinel Response Playbooks:** Predefined Azure Sentinel playbooks will automatically handle known security incidents, such as isolating risky devices, disabling stolen accounts, and sending alerts to security personnel.

III. Implementation Strategy & Operations

1. Implementation Roadmap and Phasing Plan

To transform from design to execution, GaruDyne will enforce Zero Trust via a staged roadmap that relates to the CISA Zero Trust Maturity Model v2.0. Each stage builds upon the previous, providing quantifiable maturity gains across Identity, Devices, Networks, Applications, and Data.

Phase	Timeline	Objectives	Key Actions / Milestones	Dependencies / Risks
Phase 1 – Foundational	0-12 months	Setup identity, device, and network baselines.	implement MFA and SSO through Microsoft Entra ID and Okta. Register all endpoints in Intune and CrowdStrike; facilitate SIEM logging and baseline monitoring in Splunk.	Collaboration delays between legacy HR and identity systems; user onboarding challenges with MFA.
Phase 2 – Integrated	12–30 months	Enable contextual access and micro segmentation across CAD, HR, Supplier Portal, and R&D systems.	Rollout Cisco ISE for NAC; provision Zscaler ZPA for VPN-less access; implement device compliance policies; categorize data via Microsoft Purview.	Legacy application compatibility; network latency calibration for ZTNA.
Phase 3 – Optimized	30-48 months	Automate policy governance and continuous validation.	Integrate SIEM feedback with Entra Conditional Access; Deploy automated risk-based access playbooks; establish Zero Trust dashboard for executive metrics.	Change management challenges; process standardization delays.

Each phase concludes with an internal maturity assessment to validate progress from *Initial* → *Advanced* → *Optimal* per CISA ZTMM metrics. Zero trust transformation over a large scale typically takes 36-48 months (about 4 years) due to identity modernization, data

classification workflows, OT segmentation complexity, and organizational change management.

2. Operational Processes and Governance Model

A sustainable Zero Trust network architecture requires clear roles, repeatable processes, and feedback loops integrating technical controls to governance.

Governance Structure

Role	Responsibility
CISO	Executive sponsor; sanctions ZT strategy and budget.
Zero Trust Program Manager	Plans and coordinates roadmap execution across IAM, Network, SOC, and Compliance teams.
SOC Lead / Blue Team	Oversee SIEM/UEBA triggers incident response and policy adjustments.
IAM Team	Configure Entra ID and Okta policies, identity governance, and privilege reviews.
Network Ops	Manage Cisco ISE and Zscaler configurations; enforce micro segmentation.
Data Governance Officer	Supervise Purview classifications, DLP, and compliance with ITAR and GDPR.

Policy Lifecycle Management

Policies are version-controlled in Git and analyzed quarterly. Quarterly reviews provide enough time for measuring trend analysis without extra pressure on the IAM team and match with typical enterprise change cycle. Changes go through peer review and automated testing in a staging environment before deployment.

Continuous Validation

- Device posture verified every 4 hours by Intune + CrowdStrike. A 4-hour cycle provides enough time for detecting posture changes without disrupting normal user workflow.
- Session risk scores from UEBA are supplied into Entra Conditional Access for adaptive re-authentication.
- SIEM alerts initiate policy updates through Sentinel playbooks.

Incident Response Integration

Zero Trust telemetry (SIEM → SOC → Policy Engine) provide a quick contingency:

- Warning triggered by UEBA.
- SOC validates and deploys Sentinel playbook.
- Policy Engine denies tokens or isolates devices via ISE.
- Incident documented in the ServiceNow IR module.

Change Control / Exceptions

Temporary access is approved by IAM manager, time-boxed in Entra ID, and audited weekly via SIEM reports.

3. Metrics and Measure of Success

Key Risk Indicators (KRIs) and Key Performance Indicators (KPIs) will be used to evaluate how effectively GaruDynes's Zero Trust implementation is operating and to provide clear reporting and visibility for leadership.

Metric	Description	Measurement Method	Goal
Policy Compliance Rate	Percentage of users and devices that meet all the required trust scores and security requirements.	SEIM logs + Cisco ISE NAC data	Greater than or equal to 95%
MFA Enrollment	Number of users successfully enrolled in the MFA through Okta or Entra ID.	Identity Provider (IdP) metrics	100%
Device Posture Accuracy	Percentage of devices with active EDR, full disk encryption, and compliant security configurations.	Intune + CrowdStrike compliance reports	Greater than or equal to 98%
Mean Time to Remediate	Amount of time required to isolate and remediate devices that are non-compliant to the current policies.	SOC dashboards + EDR data	< 2 hours
Unauthorized Access Attempts	Number of attempts that are blocked due to non-compliance with the policies every month.	Cisco ISE and Zscaler Policy Enforcement Logs	Downward trend

Data Classification Coverage	Percentage of storage repositories that are classified and labeled through Purview.	DLP and Purview reports	90% within 12 months
-------------------------------------	---	-------------------------	----------------------

These measurements will help the organization track how the Zero Trust implementation is working and identify the areas that need to be improved. Tracking these indicators regularly allows the team to identify device issues, policy gaps, and user risks at an early stage. These metrics will help the management to clearly understand the progress towards the maturity goals.

4. Operational Example Scenario

Scenario: Suspicious Login Attempt Detected and Quarantined via Policy enforcement.

- An engineer tries to login into the company website from an unusual location and on a different device with different IP addresses.
- Microsoft Entra ID detects the unusual login location and marks it as suspicious and increases the user's risk score.
- Conditional Access issues an MFA challenge, and CrowdStrike verifies that the device is compliant.
- After properly analyzing the login behavior, Splunk UEBA flags it as medium risk and alerts an Azure Sentinel playbook.
- The Sentinel playbook updates the current access policy to enforce step-up authentication and limits the engineers' access to the network through ZPA.
- This current session is placed into a restricted-access VLAN/SGT by Cisco ISE which allows the SOC analyst to review the user's activity.
- SOC analysts will investigate the current event then decide either to restore full access or to terminate the current session token.
- The event is properly logged, and this data will be used to improve future risk models and to adapt its policy decisions.

This current scenario demonstrates how ZTA will continuously validate and automate the response by working together with all the components across the Zero Trust Architecture.

5. Sustainability and Continuous Improvement

- **Maturity Progression:** GaruDyne's aims to reach Zero Trust maturity within the upcoming 36-48 months (about 4 years) by improving identity, device, and network controls. With quarterly reviews, the CISA Zero Trust Maturity Model ensures that the total progress is documented and properly reviewed.

- **Technology Review Cycle:** GaruDyne will review its Zero Trust technologies Every year to identify its outdated tools, remove legacy systems, and remediate with new technologies such as improved threat detection and ZTNA platforms. An annual review matches vendor update patterns, contract timelines, and helps avoid unnecessary disruptions.
- **Training and Awareness:** Quarterly Zero Trust training will be mandated for the technical staff to stay updated and aware of new tools, policies, and procedures. Quarterly training aligns with the SOC/NOC operational cycles while avoiding excess pressure on analysts. End-users will be enrolled in security awareness training twice a year to reduce risks such as unsafe device use, phishing, data classification, and handling mistakes. Completion rates will be monitored, and a few extra certification courses will be suggested if the employees fail to achieve optimal scores in this campaign.
- **Audit and Compliance:** Security policies and configurations will be audited twice a year to identify the gaps or outdated rules. Automated tools will be used to maintain compliance with requirements such as ITAR, CMMC, and GDPR. If any issues are found during these audits, they will be added to the improvement plan and will be tracked until these issues are resolved.

6. Threat and Risk Context

Adversarial Tactic	Mitigation in Implementation plan
Credential Phishing	Enforcing MFA, using conditional access based on the dynamic trust score to restrict suspicious logins and enabling automatic session revocation to stop compromised sessions.
Lateral Movement	Applying micro-segmentation throughout the network with Cisco ISE and ZPA and enforcing least privilege policies across all systems to prevent lateral movement.
Data Exfiltration	Using CASB and Microsoft Purview DLP to inspect and control all the data movements across the network. SIEM will be placed to identify abnormal and high-risk events.

GaruDyne's Zero Trust approach will reduce the overall risk of exposure and support compliance with requirements by enforcing continuous verification, automation, and strong governance. This current plan will provide a detailed path from basic security controls to a more automated and adaptive defense which aligns with long-term business continuity and security goals.

IV. Conclusion

The Zero Trust Architecture described in this Solution Design Document delivers GaruDyne Aeronautics with a clear, impactful, and scalable path toward safeguarding its global engineering, manufacturing, and supply-chain operations. By transforming from a perimeter-based model to an identity-, device-, and context-driven secure infrastructure, GaruDyne can significantly decrease the risks related to credential compromise, supplier access, OT system exposure, and the security of critical CAD and R&D data.

The proposed framework—built on Microsoft Entra ID, Okta, Cisco ISE, Zscaler ZPA, Intune, CrowdStrike, Microsoft Purview, and Splunk SIEM—provides a unified ecosystem for continuous validation and least-privilege access across IT, OT, and cloud resources. With a phased roadmap mapped to NIST SP 800-207, NIST SP 1800-35, and the CISA Zero Trust Maturity Model, GaruDyne can push itself from foundational security controls to a mature, dynamic, and automation driven Zero Trust operating model over a realistic multi-year timeline.

Enforcing this strategy will enhance GaruDyne’s defense posture against nation-state adversaries, improve supply-chain errors, upgrade protection for sensitive aerospace designs, and be compliant with ITAR, CMMC, GDPR, and FAA regulations.

Significantly important, the operational processes, governance model, and continuous-improvement mechanisms ensure that Zero Trust becomes an enduring organizational capability rather than a one-time project.

References

CISA. (2023). Zero Trust Maturity Model (Version 2.0). Cybersecurity and Infrastructure Security Agency.

<https://www.cisa.gov/zero-trust-maturity-model>

NIST. (2020). NIST Special Publication 800-207: Zero Trust Architecture. National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-207>

Department of Defense. (2020). *Cybersecurity Maturity Model Certification (CMMC), Version 2.0*. U.S. Department of Defense.

<https://dodcio.defense.gov/CMMC/>